

Séance 9

SQL & Contre-Mesures

L'objectif du jour est de découvrir un premier type d'attaque non plus au niveau du réseau mais au niveau applicatif (base de données et injections SQL).

Note 1 : Lorsque des commandes nécessitant des privilèges administrateurs seront utilisées, il sera nécessaire d'utiliser la commande *sudo* sous Debian GNU/Linux et *doas* sous OpenBSD.

Note 2 : Pour mettre ServMutillidae en FR : *sudo loadkeys fr*

Note 3 : Sur les dernières versions de VirtualBox, il peut être nécessaire de réaliser une étape de configuration pour que l'ensemble des adresses IP puissent être utilisées (et vboxnet1 créé). L'étape en question consiste à créer un fichier *"/etc/vbox/networks.conf"* contenant *"* 0.0.0.0/0 ::/0"* et à relancer VirtualBox. Pour en savoir plus : https://www.virtualbox.org/manual/ch06.html#network_hostonly

A. Mise en oeuvre de l'attaque (Attaquant)

Ici nous allons avoir besoin d'à minima deux machines et du routeur permettant de les interconnecter. Il s'agira 1) du client Debian ou de l'attaquant Kali et 2) du serveur Mutillidae.

a. Découverte des hôtes et services présents sur un réseau local

Q1. En utilisant nmap, quelle commande peut être utilisée pour réaliser un scan du serveur 172.16.10.5 ? Que permet de mettre en évidence cette commande pour les services Apache2 et MySQL ?

b. Mise à jour de l'application Mutillidae

Pour ce TP, nous allons travailler à partir de la base de données « owasp10 ». Pour cela, une modification de configuration sur la machine virtuelle « Mutillidae » est nécessaire.

Q2. Répondez aux questions suivantes :

1. Qu'est ce que OWASP ?

(Source Potentielle : <https://owasp.org/about/>)

2. A quoi correspond le Top 10 OWASP ? Listez ces vulnérabilités.

(Source potentielle : <https://owasp.org/www-project-top-ten/>)

3. Qu'est ce que le Top 10 IoT ? Listez ces vulnérabilités.

(Source : <https://owasp.org/www-chapter-toronto/assets/slides/2019-12-11-OWASP-IoT-Top-10---Introduction-and-Root-Causes.pdf>)

- En vous connectant au serveur MySQL sur la machine Multillidae, vérifiez que cette base de données existe bien.

Notes :

- 1) Pour vous connecter à MySQL : `sudo mysql` ou `mysql -u root`
- 2) Vous pouvez également utiliser les commandes de base suivantes pour l'administration de bases de données d'un serveur MySQL :
 - `SHOW DATABASES ;` ⇒ Liste les bases disponibles.
 - `USE nom_de_la_base ;` ⇒ Définit la base de données à utiliser (sur laquelle se positionner).
 - `SHOW TABLES ;` ⇒ Liste les tables d'une base de données.
 - `DESCRIBE nom_de_la_table ;` ⇒ Affiche la structure d'une table (champs et types).

Q3. Donnez le schéma relationnel de cette base de données.

Pour l'application web Mutillidae, les paramètres d'accès à la base de données sont définis dans le fichier "config.inc" situé à la racine des sources de l'application (/var/www/mutillidae/).

- Mettre à jour ces paramètres pour utiliser la base de données « owasp10 » (les autres paramètres ne sont pas à modifier).

c. L'injection SQL : Qu'est ce que c'est ?

Q4. Répondez aux différentes questions suivantes :

- Qu'est ce qu'une injection SQL ou injection LDAP ?
- Quand peut se produire ce genre d'attaques ?
- Quelles en sont les conséquences ?

(Source : <https://www.vaadata.com/blog/sql-injections-principles-impacts-exploitations-security-best-practices/>)

- Quels outils peuvent être utilisés pour automatiser la détection et l'exploitation des vulnérabilités SQLi ?

(Source potentielle : <https://www.sebastien-gandossi.fr/blog/injections-sql/>)

De nombreux exemples d'injections SQL sont disponibles sur Internet. Wikipedia donne un exemple simple qui illustre le fonctionnement d'une requête SQL afin de compromettre le mot de passe d'un utilisateur.

On considère le champ associé au login et le champ associé au mot de passe et on suppose que l'attaquant connaît le login de la victime (voir les techniques d'ingénierie

sociale et de manipulation). La saisie suivante peut être mise en place si le site est sensible aux injections SQL :

- Utilisateur : admin
- mot de passe : ' or 1 --

L'apostrophe indique la fin de la zone de frappe de l'utilisateur, le code « or 1 » demande au script si 1 est vrai, or c'est toujours le cas, et les doubles tirets indiquent le début d'un commentaire.

La requête SQL pourra ainsi ressembler à ceci :

```
select uid FROM Users where Name = 'admin' AND Password = '' OR 1 -- ;
```

Le script devient ainsi programmé pour vérifier si ce que l'utilisateur saisit est vrai. Comme 1 est vrai, l'attaquant sera connecté en tant qu'administrateur.

d. Travaux préparatoires

L'accès à l'application Mutillidae se fait ici à partir de l'URL : <http://172.16.10.5/mutillidae/>.

- Il faut commencer par créer un compte sur Mutillidae. Pour cela, cliquez sur le lien Login/Register et enregistrez vous.

Une fois authentifié, une indication apparaît en haut à droite de l'écran.

Not Logged In => **Logged In User: patrice ()**

Le niveau de sécurité du code mis en place est indiqué en haut de la page près des informations d'authentification.

Q5. Quels sont les différents niveaux de sécurité avec Mutillidae ? A quoi correspondent-ils ?

(Source potentielle : [https://hausec.com/web-pentesting-write-ups/mutillidae/xss/bypassing-javascript-client-side-validation/#:~:text=In%20Mutillidae%2C%20security%20is%20changeable,\(i.e.%20filtering%20certain%20characters\)](https://hausec.com/web-pentesting-write-ups/mutillidae/xss/bypassing-javascript-client-side-validation/#:~:text=In%20Mutillidae%2C%20security%20is%20changeable,(i.e.%20filtering%20certain%20characters)))

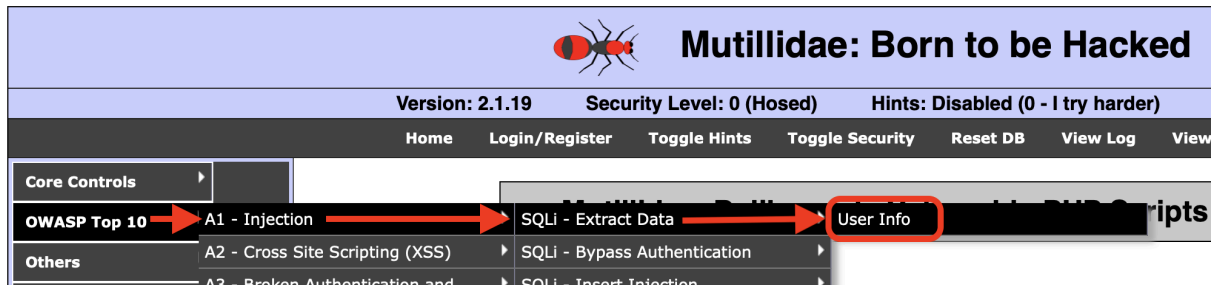
Le niveau de sécurité du code mis en œuvre se modifie en cliquant sur le lien Toggle Security.

Toggle Security

Chaque niveau de sécurité est disponible sur le même script PHP. Ces scripts sont stockés sur le serveur dans le répertoire /var/www/html/mutillidae/.

e. Réalisation d'une injection SQL - Extraction de données

Pour tester l'injection SQL, vous devez vous positionner sur le menu « Owasp Top 10 → A1 Injection → SQLi Extract Data » → « User info » avec un niveau de sécurité 0 :



L'application mise à disposition dans ce cas est un formulaire chargé d'afficher les informations de l'utilisateur qui se connecte.

**Please enter username and password
to view account details**

Name

Password

View Account Details

Notez que dans les séances suivantes il pourra vous être nécessaire de connaître les noms des champs de formulaires utilisés. Cette information peut s'obtenir facilement en observant le code source de la page (CTRL + U).

```
<td class="label">Username</td>
<td>
  <input SQLInjectionPoint="1" type="text" name="username" size="20"
    autofocus="autofocus"
    minlength="1" maxlength="15" required="required" />
```

Notez également que l'outil que vous installerez à la fin de cette séance peut-être utilisé pour mener ces différentes attaques.

Un attaquant va dans un premier temps essayer de récupérer des informations sur la structure de la base de données en tentant de provoquer une erreur de syntaxe au moment de l'exécution de la requête SQL utilisée pour valider l'authentification sur l'application.

Pour cela, un exemple d'identifiants peut être :

- login : hacker
- mot de passe : '

Note : La valeur du mot de passe est bien une apostrophe.

Tentez une connexion avec ces paramètres.

Q6. Expliquez en quoi les informations affichées peuvent être utiles pour un attaquant. En quoi dévoilent-elles la sensibilité SQLi ?

L'outil *Web Developer* de Firefox peut également être utilisé afin de rendre visible les données saisies dans le champ associé au mot de passe. Cette manipulation n'est pas indispensable, elle sert uniquement à illustrer la saisie de l'apostrophe.

Les paramètres de connexion précédents (avec un caractère spécial, l'apostrophe) étant autorisés, l'attaquant sait qu'il va pouvoir tenter une attaque de type injection SQL.

Le principe est d'injecter une opération toujours vraie afin que la requête SQL exécutée au moment de la validation de l'authentification soit correcte même si le login n'existe pas dans la base.

Vous allez tester les identifiants suivants :

- Login = *hacker*
- Mot de passe = *'or 'a' = 'a*

Q7. Expliquez l'affichage obtenu. Comment le justifiez-vous ?

f. Réalisation d'une injection SQL - Passer outre une authentification

A ce stade, le but d'un attaquant pourrait être de s'authentifier à l'aide du compte d'un autre utilisateur. Pour réaliser cela, il faut suivre le cheminement suivant : OWASP 2017 => A1 – Injection (SQL) => SQLi – Bypass Authentication => Login.

OWASP 2017	A1 - Injection (SQL)	SQLi - Extract Data	
OWASP 2013	A1 - Injection (Other)	SQLi - Bypass Authentication	Login

Q8. En vous basant sur les informations obtenues précédemment, authentifiez vous et prouvez que cela a fonctionné par une capture d'écran.

B. Mise en Place d'une contremesure

- Positionnez le niveau de sécurité de l'application Mutillidae à 5 en cliquant deux fois sur le bouton « Toggle Security » (barre de menu haute).



Q9. Tentez à nouveau l'injection SQL précédente et expliquez le résultat obtenu.

Le code source gérant l'authentification sur l'application Mutillidae est dans la page «login.php» (dans /var/www/mutillidae).

Q10. Comparez le code dans sa version sécurisée et dans sa version non sécurisée et répondez aux questions suivantes :

- Expliquez comment le code sécurisé de la page login.php permet d'empêcher l'injection SQL.
- Quels sont donc les contrôles nécessaires pour se protéger d'une attaque ?
- Comment la validation javascript est-elle déclenchée ?
- Quels sont les contrôles réalisés par la validation Javascript ?

Q11. Pour aller plus loin, en analysant le code des fichiers login.php et user-info.php, expliquez les différences entre les niveaux de sécurité 1 (et plus 0) et 5.

Q12. Proposez une conclusion sur l'intérêt d'un codage sécurisé au regard des principes fondamentaux de la sécurité (disponibilité, intégrité et confidentialité).

C. Préparation de la séance future : BurpSuite et premiers tests

Dans la séance suivante sur OWASP, nous aurons besoin d'utiliser BurpSuite.

Q13. Qu'est ce que BurpSuite ? Quel peut-être l'intérêt d'utiliser un tel outil ?

(Source potentielle :
<https://www.vaadata.com/blog/introduction-to-burp-suite-the-tool-dedicated-to-web-application-security/>)

a. Installation

- Installez BurpSuite sur la machine cliente.

BurpSuite est disponible en version gratuite et en version payante avec des fonctionnalités avancées. Nous installerons la version gratuite (Community).

Le téléchargement se fait via le lien suivant en utilisant un navigateur:

<https://portswigger.net/burp/releases/professional-community-1-7-32>

Choisir la version communautaire et cliquer sur le bouton Download. Puis, choisir la version pour Linux (64 bits). Le script téléchargé doit être exécutable.

chmod +x burpsuite_community_linux_1_7_32.sh

Le lancement de l'installation peut commencer.

sh burpsuite_community_linux_1_7_32.sh

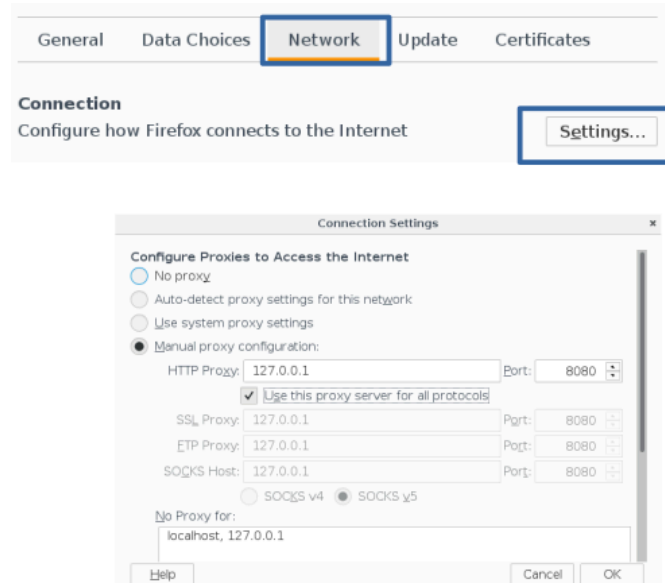
Il ne reste plus qu'à finaliser l'installation en cliquant sur le bouton Next et en laissant les valeurs par défaut.

a. Configuration du navigateur

Lorsqu'il sera nécessaire d'utiliser Burpsuite, le navigateur devra être configuré pour l'utiliser en tant que proxy. Avec Firefox, il faut aller dans Édition puis Préférences ou saisir `about:preferences` dans l'url afin d'accéder aux options avancées de configuration.

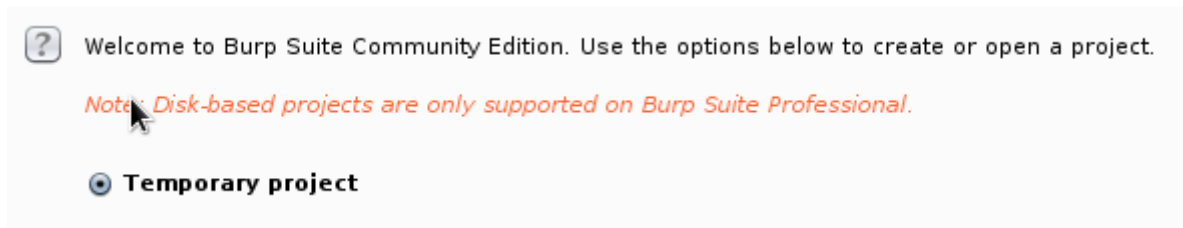
Puis, dans l'onglet réseau, il faut cliquer sur paramètres et faire référence au proxy BurpSuite. L'écoute se fait sur le port 8080.

Ensuite, il faut indiquer l'adresse de bouclage 127.0.0.1 ainsi que le port d'écoute 8080.

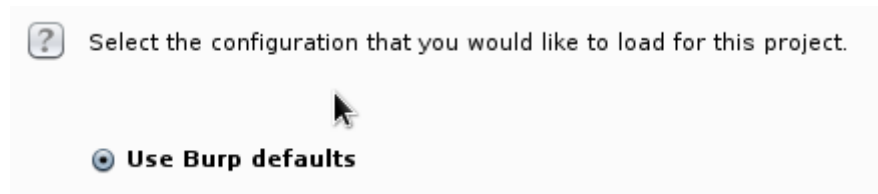


b. Première capture de paquet

Lancez BurpSuite et cliquez sur temporary project



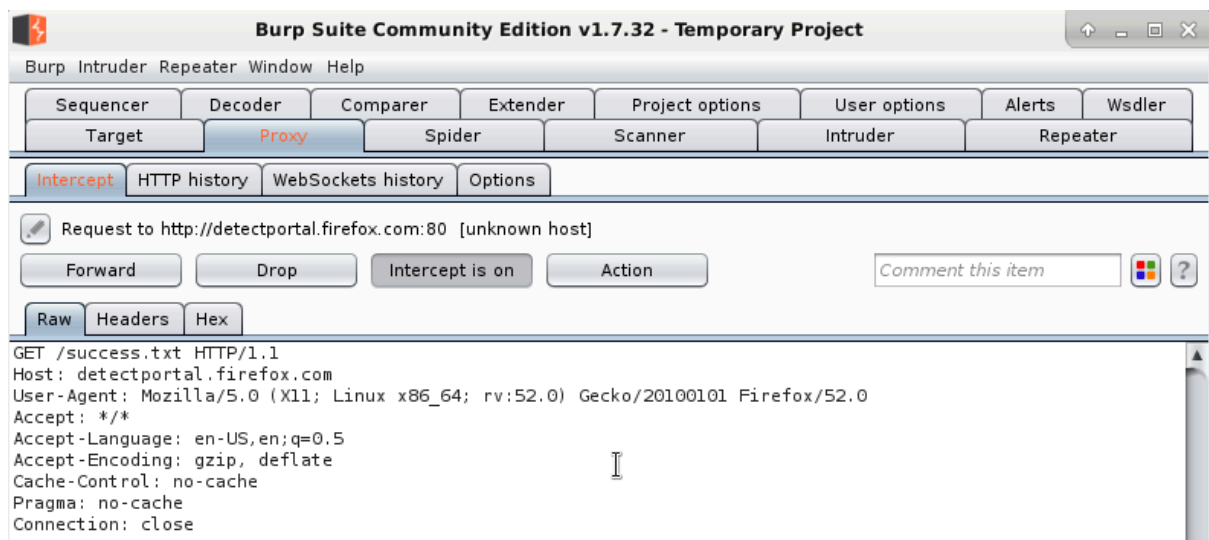
Puis un autre clic sur suivant et enfin sur burp defaults.



Enfin, il faut cliquer sur le bouton Start Burp.

Le répertoire d'installation de BurpSuite se situe par défaut dans /usr/local/BurpSuiteCommunity. Pour effectuer une première interception de requête, il faut cliquer sur l'onglet Proxy, puis sur Intercept et vérifier la présence du bouton intercept is on. Lors de l'accès à un site depuis le navigateur, chaque requête est capturée par BurpSuite. Le clic sur le bouton Forward permet de passer à la requête suivante. En attendant ce clic, le proxy se met en attente avant d'envoyer les données vers le serveur web.

Pour désactiver la capture, il suffit de cliquer sur 'intercept is on'.



1.

Q14. Joignez à votre rapport une capture d'écran prouvant que vous avez réalisé ces différentes étapes